

PraxisFlow AI – Rollen- und Rechtemodell

Version: 1.0.0 | Datum: 31.08.2026 | Status: Phase 1 – Entwurf

1. Designprinzipien

- **Least Privilege:** Jede Rolle erhält nur die minimal notwendigen Rechte
- **Serverseitige Prüfung:** Berechtigungen werden ausschliesslich auf dem Server geprüft
- **Deny by Default:** Kein Zugriff, wenn keine explizite Berechtigung vorliegt
- **Mandantentrennung:** Rechte gelten immer nur innerhalb eines Mandanten (tenantId)
- **Keine Frontend-only-Sicherheit:** Die UI blendet Optionen aus, aber der Server verwirft unberechtigte Requests

2. Systemrollen (unveränderlich)

Rolle	Code	Beschreibung
Ärztin/Arzt	ARZT	Medizinische Vorgänge, Freigaben, klinische Entscheidungen
MPA Empfang	MPA_EMPFANG	Eingänge, Termine, Rückrufe, organisatorische Aufgaben
Praxisleitung	PRAXISLEITUNG	Gesamtübersicht, Administra- tion, Auswertungen
Weiteres Personal	PERSONAL	Nur explizit zugewiesene Aufgaben
Systemadministrator	SYSADMIN	Technische Konfiguration, kein Zugriff auf Patientend- aten

3. Berechtigungsmatrix

Legende

-  Vollzugriff
-  Nur lesen
-  Lesen + Schreiben

-  Kein Zugriff
-  Nur explizit zugewiesene Elemente
-  Nur mit Protokollierung (privilegierter Zugriff)

3.1 Patienten

Berechtigung	ARZT	MPA_EMPFANG	PRAXISLEITUNG	PERSONAL	SYSADMIN
Patient anzeigen	✓	✓	✓	✗	
Patient erstellen	✓	✓	✓	✗	✗
Patient bearbeiten	✓	✓	✓	✗	✗
Patient löschen (Soft)	✓	✗	✓	✗	✗
Medizinische Daten sehen	✓			✗	✗
AHV-Nummer sehen	✓	✓	✓	✗	✗
Einwilligungen verwalten	✓	✓	✓	✗	✗
Patient exportieren	✓	✗	✓	✗	✗
Dubletten zusammenführen	✓	✗	✓	✗	✗

3.2 Eingänge

Berechtigung	ARZT	MPA_EMPFANG	PRAXISLEITUNG	PERSONAL	SYSADMIN
Alle Eingänge sehen	✓	✓	✓	✗	✗
Eingang erstellen	✓	✓	✓	✗	✗
Eingang bearbeiten	✓	✓	✓	✗	✗
Patientenzuordnung bestätigen	✓	✓	✓	✗	✗
Eingang archivieren	✓	✗	✓	✗	✗

3.3 Vorgänge

Berechti- gung	ARZT	MPA_EMPFA NG	PRAXISLEI- TUNG	PERSONAL	SYSADMIN
Alle Vor- gänge sehen	✓	✓	✓	✗	✗
Medizinische Vorgänge se- hen	✓	👁	👁	✗	✗
Vorgang er- stellen	✓	✓	✓	✗	✗
Vorgang bearbeiten	✓	✓	✓	✗	✗
Vorgang zu- weisen	✓	✓	✓	✗	✗
Medizinische Freigabe er- teilen	✓	✗	✗	✗	✗
Medizinische Freigabe ablehnen	✓	✗	✗	✗	✗
Vorgang ab- schliessen	✓	✗	✓	✗	✗
Vorgang löschen (Soft)	✗	✗	✓	✗	✗
Eskalation auslösen	✓	✓	✓	✗	✗

3.4 Aufgaben

Berechtig- ung	ARZT	MPA_EMPFA- NG	PRAXISLEI- TUNG	PERSONAL	SYSADMIN
Eigene Aufgaben se- hen	✓	✓	✓	🔒	✗
Alle Aufgaben se- hen	✓	✓	✓	✗	✗
Aufgabe er- stellen	✓	✓	✓	✗	✗
Aufgabe zu- weisen	✓	✓	✓	✗	✗
Aufgabe erledigen	✓	✓	✓	🔒	✗
Aufgabe löschen	✓	✗	✓	✗	✗

3.5 Dokumente

Berechtig- ung	ARZT	MPA_EMPFA- NG	PRAXISLEI- TUNG	PERSONAL	SYSADMIN
Dokumente sehen	✓	✓	✓	✗	✗
Medizinische Dokumente sehen	✓	👁	👁	✗	✗
Dokument hochladen	✓	✓	✓	✗	✗
Dokument zuordnen	✓	✓	✓	✗	✗
Ärztliche Kon- trolle bestäti- gen	✓	✗	✗	✗	✗
Dokument exportieren	✓	✗	✓	✗	✗
Dokument löschen	✗	✗	✓	✗	✗

3.6 Termine & Rückrufe

Berechti- gung	ARZT	MPA_EMPFA NG	PRAXISLEI- TUNG	PERSONAL	SYSADMIN
Termine se- hen	✓	✓	✓	✗	✗
Termin erstel- len	✓	✓	✓	✗	✗
Termin bearbeiten	✓	✓	✓	✗	✗
Termin stornieren (mit Freigabe)	✓	⚠	✓	✗	✗
Rückruf er- stellen	✓	✓	✓	✗	✗
Rückruf dok- umentieren	✓	✓	✓	✗	✗

3.7 Auswertungen & Reports

Berechti- gung	ARZT	MPA_EMPFA NG	PRAXISLEI- TUNG	PERSONAL	SYSADMIN
Eigene Stat- istiken	✓	✓	✓	✗	✗
Team-Aus- wertungen	✗	✗	✓	✗	✗
Audit-Pro- tokoll sehen	✗	✗	✓	✗	⚠
Daten expor- tieren	✗	✗	✓	✗	✗

3.8 Einstellungen & Administration

Berechtigung	ARZT	MPA_EMPFANG	PRAXISLEITUNG	PERSONAL	SYSADMIN
Benutzer verwalten	✗	✗	✓	✗	✓
Rollen zuweisen	✗	✗	✓	✗	✓
Prozesskonfiguration	✗	✗	✓	✗	✗
Integrationsstatus	✗	✗	✓	✗	✓
Technische Konfiguration	✗	✗	✗	✗	✓
Systemlogs (ohne PII)	✗	✗	✗	✗	✓

4. RBAC-Implementierung (Server)

```
// server/auth/rbac.ts

export const PERMISSIONS = {
  // Patienten
  PATIENT_READ:      'patient:lesen',
  PATIENT_WRITE:     'patient:schreiben',
  PATIENT_DELETE:    'patient:loeschen',
  PATIENT_EXPORT:    'patient:exportieren',
  PATIENT_MEDICAL:   'patient:medizinisch',

  // Vorgänge
  VORGANG_READ:      'vorgang:lesen',
  VORGANG_WRITE:     'vorgang:schreiben',
  VORGANG_CLOSE:     'vorgang:abschliessen',
  VORGANG_DELETE:    'vorgang:loeschen',
  VORGANG_APPROVE:   'vorgang:freigeben', // Nur ARZT

  // Eingang
  EINGANG_READ:      'eingang:lesen',
  EINGANG_WRITE:     'eingang:schreiben',

  // Aufgaben
  AUFGABE_READ:      'aufgabe:lesen',
  AUFGABE_WRITE:     'aufgabe:schreiben',
  AUFGABE_DELETE:    'aufgabe:loeschen',

  // Dokumente
  DOKUMENT_READ:     'dokument:lesen',
  DOKUMENT_WRITE:    'dokument:schreiben',
  DOKUMENT_DELETE:   'dokument:loeschen',
  DOKUMENT_MEDICAL:  'dokument:aerztlich',
  DOKUMENT_EXPORT:   'dokument:exportieren',

  // Termine
  TERMIN_READ:       'termin:lesen',
  TERMIN_WRITE:      'termin:schreiben',
  TERMIN_CANCEL:     'termin:stornieren',

  // Rückrufe
  RUECKRUF_READ:     'rueckruf:lesen',
  RUECKRUF_WRITE:    'rueckruf:schreiben',

  // Auswertungen
  AUSWERTUNG_READ:   'auswertung:lesen',
  AUSWERTUNG_EXPORT: 'auswertung:exportieren',
  AUDIT_READ:        'audit:lesen',

  // Administration
  BENUTZER_MANAGE:   'benutzer:verwalten',
  ROLLE_MANAGE:      'rolle:verwalten',
  SYSTEM_CONFIG:     'system:konfigurieren',
  INTEGRATION_READ:  'integration:lesen',
  INTEGRATION_CONFIG: 'integration:konfigurieren',
} as const;

// Standard-Rollenzuweisungen
export const ROLE_PERMISSIONS: Record<string, string[]> = {
  ARZT: [
    PERMISSIONS.PATIENT_READ, PERMISSIONS.PATIENT_WRITE,
    PERMISSIONS.PATIENT_DELETE, PERMISSIONS.PATIENT_MEDICAL,
    PERMISSIONS.VORGANG_READ, PERMISSIONS.VORGANG_WRITE,
    PERMISSIONS.VORGANG_CLOSE, PERMISSIONS.VORGANG_APPROVE,
  ],
}
```

```

        PERMISSIONS.EINGANG_READ, PERMISSIONS.EINGANG_WRITE,
        PERMISSIONS.AUFGABE_READ, PERMISSIONS.AUFGABE_WRITE,
        PERMISSIONS.DOKUMENT_READ, PERMISSIONS.DOKUMENT_WRITE,
        PERMISSIONS.DOKUMENT_MEDICAL,
        PERMISSIONS.TERMIN_READ, PERMISSIONS.TERMIN_WRITE, PERMISSIONS.TERMIN_CANCEL,
        PERMISSIONS.RUECKRUF_READ, PERMISSIONS.RUECKRUF_WRITE,
        PERMISSIONS.AUSWERTUNG_READ,
    ],
    MPA_EMPFANG: [
        PERMISSIONS.PATIENT_READ, PERMISSIONS.PATIENT_WRITE,
        PERMISSIONS.VORGANG_READ, PERMISSIONS.VORGANG_WRITE,
        PERMISSIONS.EINGANG_READ, PERMISSIONS.EINGANG_WRITE,
        PERMISSIONS.AUFGABE_READ, PERMISSIONS.AUFGABE_WRITE,
        PERMISSIONS.DOKUMENT_READ, PERMISSIONS.DOKUMENT_WRITE,
        PERMISSIONS.TERMIN_READ, PERMISSIONS.TERMIN_WRITE,
        PERMISSIONS.RUECKRUF_READ, PERMISSIONS.RUECKRUF_WRITE,
        PERMISSIONS.AUSWERTUNG_READ,
    ],
    PRAXISLEITUNG: [
        PERMISSIONS.PATIENT_READ, PERMISSIONS.PATIENT_WRITE,
        PERMISSIONS.PATIENT_DELETE, PERMISSIONS.PATIENT_EXPORT,
        PERMISSIONS.VORGANG_READ, PERMISSIONS.VORGANG_WRITE,
        PERMISSIONS.VORGANG_CLOSE, PERMISSIONS.VORGANG_DELETE,
        PERMISSIONS.EINGANG_READ, PERMISSIONS.EINGANG_WRITE,
        PERMISSIONS.AUFGABE_READ, PERMISSIONS.AUFGABE_WRITE, PERMISSIONS.AUFGABE_DELETE,
        PERMISSIONS.DOKUMENT_READ, PERMISSIONS.DOKUMENT_WRITE,
        PERMISSIONS.DOKUMENT_DELETE, PERMISSIONS.DOKUMENT_EXPORT,
        PERMISSIONS.TERMIN_READ, PERMISSIONS.TERMIN_WRITE, PERMISSIONS.TERMIN_CANCEL,
        PERMISSIONS.RUECKRUF_READ, PERMISSIONS.RUECKRUF_WRITE,
        PERMISSIONS.AUSWERTUNG_READ, PERMISSIONS.AUSWERTUNG_EXPORT, PERMIS-
SIONS.AUDIT_READ,
        PERMISSIONS.BENUTZER_MANAGE, PERMISSIONS.ROLLE_MANAGE,
        PERMISSIONS.INTEGRATION_READ,
    ],
    PERSONAL: [
        // Nur explizit zugewiesene Aufgaben – wird über Filterlogik umgesetzt
        PERMISSIONS.AUFGABE_READ,
    ],
    SYSADMIN: [
        PERMISSIONS.BENUTZER_MANAGE, PERMISSIONS.ROLLE_MANAGE,
        PERMISSIONS.SYSTEM_CONFIG,
        PERMISSIONS.INTEGRATION_READ, PERMISSIONS.INTEGRATION_CONFIG,
        PERMISSIONS.AUDIT_READ,
        // KEIN Zugriff auf Patientendaten oder medizinische Inhalte
    ],
};

```

5. Session-Sicherheit

Session-Konfiguration

Sitzungsdauer:	4 Stunden (Verlängerung bei Aktivität)
Inaktivitäts-T0:	30 Minuten
Cookie:	HttpOnly, Secure, SameSite=Strict
Widerruf:	Sofort via Datenbank-Invalidierung (tabelle: sitzungen)
MFA:	TOTP vorbereitet (erzungen vor Echtbetrieb)

Session-Fluss

Login

- Passwort validieren (bcrypt, min. 12 Runden)
- [MFA-Code prüfen, wenn aktiv]
- Session-Token generieren (crypto.randomBytes(32))
- Session in DB speichern (mit Ablauf)
- HttpOnly-Cookie setzen
- AuditEreignis: "anmelden" (IP, UserAgent)

Jeder Request

- Cookie lesen
- Session in DB prüfen (nicht abgelaufen, nicht widerrufen)
- Benutzer laden + Rollen/Rechte
- tenantId aus Session extrahieren
- RBAC prüfen für die angeforderte Aktion

Logout

- Session in DB als widerrufen markieren (widerrufenAt = now())
- Cookie löschen
- AuditEreignis: "abmelden"

Widerruf (Admin)

- Alle aktiven Sessions des Benutzers in DB invalidieren
- AuditEreignis: "session_widerrufen" (privilegierter Zugriff)

6. Privilegierte Zugriffe (SYSADMIN)

Alle SYSADMIN-Aktionen auf medizinische oder personenbezogene Daten (z.B. Systemwartung) müssen:

1. Explizit angefordert werden (kein automatischer Zugriff)
2. Sofort im AuditEreignis protokolliert werden
3. Durch eine zweite Person bestätigt werden (4-Augen-Prinzip, vor Echtbetrieb)
4. Zeitlich begrenzt sein

7. Abnahmekriterien RBAC

- [] Jede API-Route prüft serverseitig Berechtigung via `requirePermission()`
- [] MPA kann keine medizinische Freigabe erteilen (HTTP 403)
- [] PERSONAL sieht nur eigene Aufgaben (kein anderer Datenzugriff)
- [] SYSADMIN sieht keine Patientendaten ohne explizite Anforderung
- [] Alle Freigaben (medizinisch) werden mit Zeitstempel und Person protokolliert
- [] Session-Widerruf ist sofort wirksam (nächster Request schlägt fehl)
- [] Automatisierte Berechtigungstests für alle Rollen-Ressourcen-Kombinationen